LEARNER ATTACHMENT

# HIPAA Compliance Checklist

*Tier 1 follow-and-escalate checklist for suspected security incidents involving possible ePHI*

**BOUNDARY** This checklist identifies routing and documentation obligations. The designated privacy function determines impermissible use/disclosure, breach-risk assessment, and notification obligations.

## A. Security-incident response

- Suspected or known security incident identified and incident record opened.
- Documented response procedure and assigned security function identified.
- Authorized containment and mitigation status recorded.
- Security incident and outcome documentation preserved.

## B. Possible ePHI involvement

- System, repository, and data type potentially involved are named without unnecessary PHI.
- Evidence distinguishes possible access from confirmed acquisition or viewing.
- Minimum-necessary information is used in handoffs and access is limited to authorized roles.
- Privacy/compliance trigger in PRIV-01 is evaluated.

## C. Privacy-office determination

| Question reserved for designated privacy function | Tier 1 entry |
|---|---|
| Was there an impermissible use or disclosure under the Privacy Rule? | Unresolved - cite facts only |
| Does an exception to the definition of breach apply? | Unresolved |
| Is the four-factor breach risk assessment required or will notification proceed without it? | Unresolved |
| What are the nature/extent of PHI, unauthorized recipient, actual acquisition/viewing, and mitigation? | Provide available evidence; do not score |
| Are individual, HHS, media, contractual, or state-law notifications required? | Unresolved |

## D. Documentation and handoff

- Exact timestamps, ticket number, evidence IDs, action status, and receiving owner recorded.
- Approved SOP/runbook criterion cited.
- Unresolved question stated without a breach or notification conclusion.
- No PHI or workforce identifier appears outside the approved restricted record beyond what is necessary.

## Authoritative sources

- HHS - Summary of the HIPAA Security Rule
- HHS - Summary of the HIPAA Privacy Rule
- HHS - Minimum Necessary Requirement
- HHS - Breach Notification Rule